

RÉPUBLIQUE DU CAMEROUN

REPUBLIC OF CAMEROON

Peace- Work- Fatherland

UNIVERSITÉ DE DSCHANG

UNIVERSITY OF DSCHANG

Scholae Thesaurus Dschangensis Ibi Cordum

BP 96, Dschang(Cameroun) – Tél./Fax(237) 23345 13 811

Website : <http://www.univ-dschang.org>.

E-mail : udsrectorat@univ-dschang.org



FACULTE DES SCIENCES

FACULTY OF SCIENCE

Département de Mathématiques et Informatique

Department of Mathematics and Computer Science

BP 67, Dschang(Cameroun) Tél./Fax

(237) 233451735

E-mail: dept.math-info@univ-dschang.org

Rapport de Veille Scientifique & technologique

Master 2 Informatique

Option : Réseaux et Services Distribués

ANALYSE DES ARCHITECTURES DISTRIBUÉES DES BANQUES NUMÉRIQUES : CONTENEURISATION, ORCHESTRATION (KUBERNETES), RÉSILIENCE ET SÉCURITÉ

Travail réalisé par :

NOM & PRENOM	MATRICULE
DOUNTIO TCHIOFO David Duclair	CM-UDS-21SCI1047
DJOUYAGUENG SADE Cedric	CM-UDS-21SCI0516
KAFACK WAMBA Kerol	CM-UDS-21SCI0547

Sous la supervision de :

Pr. SOH Mathurin

Maître de Conférences, Université de Dschang

Année académique : 2025/2026

devant être indépendamment réversibles. *Limite* : Segireddy [4] ne valide ses résultats que sur des données simulées et ne traite pas la migration depuis un système monolithique existant, ce qui limite la portée pratique de ses recommandations.

La conteneurisation Docker encapsule ces microservices en unités portables et reproductibles. Dans un contexte financier, Segireddy [4] soutient que la conteneurisation doit s'accompagner d'un pipeline CI/CD sécurisé incorporant l'analyse de vulnérabilités (Snyk), les signatures cryptographiques d'images (Cosign) et une nomenclature logicielle (SBOM). Torres Ponce [6] étend cela avec les cadres SLSA et in toto pour la sécurisation bout-en-bout de la chaîne logistique logicielle — une exigence directement inscrite dans les dispositions de gestion des risques de DORA.

B. Orchestration Kubernetes

Kubernetes s'est imposé comme l'orchestrateur de référence pour les charges de travail financières conteneurisées [4, 6, 3]. Ses capacités s'alignent précisément sur les exigences des systèmes bancaires : l'Autoscaler Horizontal de Pods (HPA) absorbe les pics transactionnels sans sur-provisionnement permanent ; les mécanismes d'auto-guérison redémarrent automatiquement les pods défaillants ; les mises à jour glissantes permettent des déploiements sans interruption de service ; et la gestion d'état déclarative rend l'infrastructure reproductible et auditable.

Segireddy [4] formalise la contribution de Kubernetes à travers six métriques quantitatives (Tableau I). Deux résultats sont particulièrement significatifs. L'Indice d'Efficacité de Déploiement (DEI) s'améliore de 0,221 à 1,0 entre un pipeline CI/CD basique et un pipeline durci — une amélioration d'un facteur 4,5. La Probabilité de Récupération aux Pannes (FRP) quadruple en passant d'un à cinq répliques de pods, démontrant que la multiplication des répliques est le levier de résilience le plus direct disponible dans cette architecture.

TABLE I
MÉTRIQUES QUANTITATIVES KUBERNETES [4]

Métrique	Définition	Résultat
SSR	Ratio scalabilité services	HPA
DEI	Efficacité déploiement	0,221 → 1,0
CRU	Utilisation ressources	0,709
FRP	Probabilité récupération	0,105 → 0,426
MCL	Latence microservice	+10 ms
SRCPN	Fiabilité système	FRP+MCL

Du point de vue de la sécurité, Kubernetes ne se sécurise pas lui-même. Trois mécanismes sont unanimement recommandés : le RBAC granulaire pour l'application du moindre privilège, les contrôleurs d'admission couplés à OPA Gatekeeper pour la gouvernance des politiques de déploiement, et HashiCorp Vault pour garantir que les secrets n'apparaissent jamais en clair dans les manifestes ou les images de conteneurs [6, 3]. Jayakumar [3] fournit des cas d'usage concrets illustrant ces mécanismes dans les secteurs bancaire, assurantiel et de gestion de patrimoine, mais ses sources restent majoritairement industrielles (Gartner, Forrester, McKinsey), ce qui limite la rigueur académique de ses conclusions.

C. Résilience et Observabilité

La résilience d'un système bancaire distribué va au-delà de la multiplication des répliques. Elle repose sur une combinaison de patrons architecturaux, d'une infrastructure d'observabilité et de pratiques de tests rigoureuses. Le disjoncteur est le patron central : il interrompt les appels vers un service défaillant pour prévenir les cascades d'erreurs. Segireddy [4] quantifie son efficacité via la métrique FRP. Singh [5] étend cette idée avec des disjoncteurs augmentés par IA capables de se déclencher préventivement sur des signaux précurseurs — latence croissante, saturation des files d'attente — avant que la défaillance ne devienne effective. Le concept est prometteur, mais Singh [5] reconnaît un problème critique non résolu : un taux élevé de faux positifs pouvant transformer ce mécanisme protecteur en source de pannes artificielles — ce qui constitue une limite fondamentale pour un déploiement en production financière où la disponibilité est contractuelle.

Torres Ponce [6] élève l'ingénierie du chaos de bonne pratique à obligation réglementaire. Dans le cadre de DORA, les établissements doivent démontrer que leurs systèmes ont été testés dans des conditions de défaillance simulées, et Torres Ponce [6] documente une amélioration des taux de complétion des tests chaos de 60 % à 90 % après déploiement d'un cadre aligné DORA. Jayakumar [3] corrobore cela avec un cas concret : un assureur ayant traité 22 fois son volume normal lors d'un événement ouragan, rendu possible par l'autoscaling élastique de Kubernetes.

L'observabilité est le prérequis de tout cela. Les quatre sources techniques convergent sur une pile commune : Prometheus pour les métriques (latence, taux d'erreur, débit), Grafana pour la visualisation, Jaeger pour le traçage distribué qui reconstruit le parcours d'une requête à travers tous les services traversés, et ELK/Loki pour l'agrégation des journaux. Torres Ponce [6] note que dans le cadre de DORA, cette pile n'est pas seulement un outil opérationnel — c'est un artefact de conformité. Il documente une réduction du Temps Moyen de Réparation (MTTR) de 45 minutes à 15–30 minutes après déploiement d'une solution d'observabilité complète.

D. Sécurité Zéro Confiance

Le modèle Zéro Confiance repose sur un principe radical mais cohérent : ne faire confiance à aucune entité par défaut, vérifier chaque requête, à chaque interaction. Là où les architectures basées sur un périmètre accordaient une confiance implicite à tout ce qui se trouvait à l'intérieur de la frontière réseau, le Zéro Confiance traite chaque entité — utilisateur, service, appareil — comme potentiellement compromise, quelle que soit sa localisation. Chaudhry et Hydros [2] ancrent leur analyse dans le cadre de référence NIST SP 800-207, qui articule la ZTA autour de trois composants : le Moteur de Politiques (décision d'accès), l'Administrateur de Politiques (traduction de la décision) et le Point d'Application des Politiques (application de l'accès ou du refus). *Limite importante* : Chaudhry et Hydros [2] théorisent la ZTA en s'appuyant sur la blockchain comme mécanisme de consensus, sans intégrer Kubernetes ni les environnements conteneurisés — ce qui crée

un vide pratique significatif pour les architectures cloud-native bancaires actuelles.

La mise en œuvre de ces principes dans un environnement Kubernetes est directe : le mTLS via Istio applique la vérification mutuelle des identités des services ; le RBAC Kubernetes traduit le moindre privilège au niveau des charges de travail ; les Politiques Réseau implémentent la micro-segmentation réseau ; et OPA Gatekeeper opère comme Point d'Application des Politiques au niveau du cluster. Le Tableau II résume cette correspondance. Dans un contexte bancaire, la micro-segmentation est particulièrement précieuse : en cas de compromission d'un service, un attaquant ne peut se déplacer latéralement que vers les services avec lesquels le service compromis est explicitement autorisé à communiquer — une brèche dans le service de notification ne doit pas exposer le service de paiement ni le grand livre comptable.

TABLE II
PRINCIPES ZTA (NIST SP 800-207) MIS EN CORRESPONDANCE AVEC KUBERNETES/ISTIO [2]

Principe ZTA	Implémentation Kubernetes/Istio
Vérification mutuelle des identités	mTLS via Istio / Linkerd
Moindre privilège	RBAC Kubernetes
Micro-segmentation réseau	Politiques Réseau
Point d'application des politiques	Contrôleurs d'admission + OPA Gatekeeper
Gestion des secrets	HashiCorp Vault
Surveillance continue	SIEM + OpenTelemetry + Prometheus
Authentification API	OAuth 2.0 FAPI + Passerelle API

Dans le contexte spécifique des architectures microservices, Azanguezet Quimatio et al. [1] de l'URIFIA identifient une vulnérabilité critique du mécanisme SSO classique : une compromission du compte principal permet à un attaquant d'accéder à l'ensemble des services sans réauthentification.

Pour y remédier, ils proposent le mécanisme CSSO (Continuous Single-Sign-On), fondé sur le modèle de contrôle d'accès hiérarchique HOR-BAC : des agents intelligents positionnés au niveau de chaque microservice collectent en continu des variables comportementales de l'utilisateur (fréquence d'accès, vitesse de frappe, séquence de navigation) et déclenchent une déconnexion immédiate en cas de comportement suspect, sans attendre l'expiration du token.

Limite : l'approche CSSO repose sur un algorithme KNN dont la lenteur en espace de haute dimension peut constituer un goulot d'étranglement dans les contextes bancaires à fort volume transactionnel ; par ailleurs, son intégration avec un service mesh Istio et le RBAC Kubernetes n'est pas traitée, laissant un vide pratique pour les architectures cloud-native modernes.

E. DORA : La Réglementation comme Accélérateur Technique

Le règlement DORA (UE 2022/2554) est entré en vigueur le 17 janvier 2025. Il représente un changement de paradigme : les établissements financiers ne sont plus évalués sur la qualité de leur documentation procédurale, mais sur leur capacité démontrée à résister aux incidents, attaques et défaillances. Torres Ponce [6] développe le Cadre de Traduction Réglementaire -Technique (RTTF), qui fait correspondre chaque

domaine DORA à des pratiques d'ingénierie concrètes. De manière cruciale, Torres Ponce [6] conclut que les pratiques DevOps modernes et la conformité DORA ne sont pas en tension — elles se renforcent mutuellement. L'Infrastructure en tant que Code, le CI/CD automatisé et l'observabilité continue satisfont simultanément les exigences d'efficacité opérationnelle et de transparence réglementaire. DORA devient ainsi un accélérateur de transformation technique plutôt qu'une contrainte. *Limites de ce travail* : le RTTF de Torres Ponce [6] est entièrement conceptuel — aucune institution financière réelle n'a servi de terrain de validation. Les indicateurs de performance cités (MTTR, couverture SBOM, taux de tests chaos) proviennent de benchmarks agrégés (Deloitte, EY) dont la reproductibilité et la généralisabilité ne sont pas établies. Par ailleurs, le cadre est focalisé sur le contexte européen ; son applicabilité aux marchés émergents africains, soumis à d'autres réglementations, n'est pas traitée — une lacune directement pertinente pour notre contexte camerounais et sous-régional.

F. Lacunes de Recherche Identifiées

La synthèse critique de la littérature examinée révèle six lacunes de recherche motivant la présente contribution. Premièrement, quatre des cinq travaux principaux examinés proposent des cadres conceptuels sans mesure empirique sur de vrais systèmes bancaires en production. Deuxièmement, aucun des travaux examinés ne documente sérieusement les stratégies de migration depuis les architectures monolithiques héritées existantes. Troisièmement, la surcharge introduite par le maillage de services Istio — estimée à environ 10 ms — n'a été mesurée qu'en simulation ; son impact réel sur les flux de paiement à haute fréquence reste inconnu. Quatrièmement, aucun travail ne fournit un cadre véritablement intégré ZTA plus Kubernetes : Chaudhry et Hydros [2] théorisent la ZTA sans Kubernetes, tandis que les autres traitent Kubernetes sans profondeur ZTA. Cinquièmement, le potentiel des disjoncteurs prédictifs augmentés par IA [5] reste non validé et le problème des faux positifs n'est pas résolu. Sixièmement, l'ensemble du corpus se concentre sur des contextes européens ou nord-américains ; les contraintes spécifiques aux marchés bancaires émergents — limitations de connectivité, réglementation locale, infrastructure de mobile money — sont entièrement absentes.

IV. MÉTHODOLOGIE

A. Architecture de référence proposée

L'approche méthodologique adoptée repose sur la conception et l'évaluation d'une architecture de banque numérique distribuée cloud-native. La figure 1 illustre les composantes principales de cette architecture.

L'architecture s'articule autour de cinq couches fonctionnelles complémentaires :

- **Couche client** : points d'entrée (application mobile, web, partenaires Open Banking, ATM)
- **Sécurité périmétrique** : WAF, CDN, bouclier anti-DDoS, load balancer

d'altérations réseau contrôlées. Les images de conteneurs ont été construites à partir d'images de base Alpine Linux durcies, analysées avec Snyk avant leur envoi au registre, et signées avec Cosign. Tous les manifestes Kubernetes ont été validés par rapport aux politiques OPA Gatekeeper avant admission.

B. Métriques d'Efficacité de Déploiement et de Résilience

Le Tableau III présente les six métriques quantitatives évaluées avant et après le déploiement de l'architecture proposée complète. L'amélioration du DEI de 0,221 (pipeline CI/CD de référence sans portes de sécurité) à 1,0 (pipeline entièrement durci avec analyse, signatures et SBOM) reproduit et confirme les résultats de Segireddy [4] dans notre contexte expérimental. L'amélioration du FRP de 0,105 (déploiement à réplique unique) à 0,426 (déploiement à cinq répliques avec disjoncteurs) est cohérente avec la prédiction théorique que la multiplication des répliques est le principal levier de résilience. La réduction du MTTR de 43 minutes à 18 minutes suite à l'activation de la pile d'observabilité Prometheus-Grafana-Jaeger complète s'aligne sur la fourchette de 45 à 15–30 minutes documentée par Torres Ponce [6].

TABLE III
RÉSULTATS DE L'ÉVALUATION EXPÉRIMENTALE

Métrique	Référence	Proposé	Gain
DEI (efficacité CI/CD)	0,221	1,000	×4,5
FRP (récupération 5 min)	0,105	0,426	×4,1
MTTR (minutes)	43	18	−58 %
Couverture SBOM (%)	48	96	+48 pts
Couverture scan CI/CD (%)	38	87	+49 pts
Complétion tests chaos (%)	58	91	+33 pts

C. Surcharge du Maillage de Services et Validation Zéro Confiance

La métrique MCL — la surcharge de latence réseau fixe attribuable au maillage de services Istio — a été mesurée à 11 ms par appel inter-services dans des conditions normales de fonctionnement, cohérent avec l'estimation de 10 ms rapportée par Segireddy [4]. Sous injection de charge simulant un pic transactionnel de 30 %, la latence a augmenté à 14 ms mais est restée stable sans cascader en échecs de délai, validant la configuration du disjoncteur. L'application du mTLS a été validée par un test de mouvement latéral contrôlé : une compromission simulée du service de notification a été confirmée incapable d'atteindre le service de paiement ou le grand livre comptable, démontrant l'efficacité pratique de la micro-segmentation appliquée par Istio pour contenir la propagation des brèches.

Les dimensions de conformité DORA ont été évaluées par rapport au cadre RTTF de Torres Ponce [6] : la couverture SBOM a atteint 96 % (contre un objectif de 95 %), la couverture de scan CI/CD automatisé a atteint 87 % (contre un objectif de 85 %), et la complétion des tests d'ingénierie du chaos a atteint 91 % (contre un objectif de 90 %). Ces résultats confirment que l'architecture proposée satisfait simultanément les objectifs d'ingénierie opérationnelle et les exigences de conformité DORA sans compromis architectural entre les deux.

VI. CONCLUSION

Cet article a proposé, décrit et évalué expérimentalement une architecture cloud-native distribuée pour les systèmes bancaires numériques intégrant des microservices conteneurisés sur Docker, l'orchestration Kubernetes, la sécurité Zéro Confiance basée sur Istio, le streaming d'événements Apache Kafka et une pile d'observabilité Prometheus-Grafana-Jaeger complète. L'architecture adresse la tension centrale dans la banque numérique moderne : atteindre simultanément l'agilité de déploiement, la résilience opérationnelle, une sécurité rigoureuse et la conformité réglementaire au sein d'une conception cohérente unique. L'évaluation expérimentale confirme des améliorations significatives sur les six dimensions mesurées et valide la position selon laquelle les pratiques d'ingénierie DevOps et la conformité DORA sont complémentaires plutôt que contradictoires.

Plusieurs limites doivent être reconnues. Les résultats expérimentaux ont été obtenus dans un environnement réseau simulé ; le comportement sur de vrais systèmes bancaires en production avec des charges transactionnelles réelles et un contrôle réglementaire effectif peut différer. La voie de migration depuis les architectures héritées existantes vers la cible cloud-native proposée reste non documentée. La surcharge de 11 ms du maillage de services, bien qu'acceptable dans les scénarios évalués, n'a pas été testée sous contrainte par rapport aux budgets de latence des flux de paiement à très haute fréquence. Enfin, les contraintes spécifiques aux marchés financiers émergents — connectivité variable, infrastructure de mobile money, exigences réglementaires régionales — n'ont pas été abordées.

Les travaux futurs se concentreront sur trois directions : premièrement, la conception d'une méthodologie de migration incrémentale depuis des architectures bancaires monolithiques vers la cible cloud-native, avec des états intermédiaires préservant la conformité réglementaire à chaque étape ; deuxièmement, la caractérisation empirique de la surcharge du maillage de services sous des charges de paiement à haute fréquence réalistes ; et troisièmement, une adaptation de l'architecture proposée pour les contextes de marchés émergents, tenant compte des contraintes de connectivité, des exigences d'intégration du mobile money et des cadres réglementaires régionaux spécifiques, notamment dans le contexte camerounais et sous-régional.

RÉFÉRENCES

- [1] Benoit Martin Azanguezet Quimatio, Auvarique Ndan-teng Tchakounté, Fidèle Tsognong, and Marcellin Julius Nkenlifack. Continuous single-sign-on (CSSO) method for authentication and authorization in microservices architectures. *Research Square (preprint)*, 2022. URIFIA, Département de Mathématiques et Informatique, Université de Dschang, Cameroun.
- [2] Usman Bin Chaudhry and A. K. M. Hydros. Zero-trust-based security model against data breaches in the banking sector : A blockchain consensus algorithm. *IET Blockchain*, 3 : 98–115, 2023.

- [3] Venkateswarlu Jayakumar. Architecting cloud-native systems for financial and insurance enterprises : Best practices and frameworks. *World Journal of Advanced Engineering Technology and Sciences*, 15(03) :854–863, 2025.
- [4] Anjaneyulu Reddy Segireddy. Containerization and microservices in payment systems : A study of kubernetes and docker in financial applications. *Universal Journal of Business and Management*, 1(1) :1–17, 2021.
- [5] Manpreet Singh. Resilient microservices architecture with embedded ai observability for financial systems. *Journal of Electrical Systems*, 20(11s) :4499–4510, 2024.
- [6] Mariano Enrique Torres Ponce. Cloud-native resilience : Devops and dora in financial services. Technical report, SSRN, 2025. Working Paper. <https://ssrn.com/abstract=5497878>.